WEP Cracking (Advanced)

Copyright © 2019 Liran Ma, Texas Christian University; Zhipeng Cai, Georgia State University; Wei Cheng, University of Washington at Tacoma
The development of this document is partially funded by the National Science Foundation's CyberTraining program under award No. OAC-1829553. Permission is granted to copy, distribute and/or modify this document under the terms of the GNU Free Documentation License, Version 1.2 or any later version published by the Free Software Foundation. A copy of the license can be found at `http://www.gnu.org/licenses/fdl.html`.

Introduction

The purpose of this lab is to continue exploring the vulnerabilities of the 802.11 WEP security protocol. It is well-known that the WEP protocol is crippled with numerous security flaws. In the *WEP Cracking via passive Listening* lab in the Eureka series, we explored the methods of exploiting these flaws when a large amount of data was present. However, it is unlikely that a sufficiently large data stream is present on a network when in regular usage. This makes the relatively easy WEP crack from the Basic lab considerably more difficult. In this lab, we will use more efficient techniques to continue exploiting the WEP protocol.

Contents

1 Information Gathering **2**

2 Testing the Injection Functionality **2**

3 Capturing Data **3**

4 Counterfeit Authentication and Association **3**

5 Traffic Generation via ARP Replay **3**

6 Key Cracking **5**

7 Network Reconnaissance **6**

8 Discussion Questions **7**

9 General Questions **7**

1 Information Gathering

Record the following information using the `airmon-ng` and `airodump-ng` tools. Verbatim instructions are included in the Basic lab.

Channel: _____

BSSID: _____

Client MAC: _____

2 Testing the Injection Functionality

The purpose of this test is to ensure that your wireless NIC can inject packets into a network. Your NIC needs to be in monitor mode for this test. It is also important that the NIC is tuned to the channel on which the target network is operating by starting `airodump-ng -c channel wlan0mon` in a separate terminal tab or window. Issue the following command:

```
# aireplay-ng -9 -e network-ssid -a bssid wlan0mon
```

The parameters should be evident, except for `-9`, which simply corresponds to an injection test. `Aireplay-ng` reference: `https://www.aircrack-ng.org/doku.php?id=aireplay-ng`.
The output of `aireplay-ng` should look like Fig. 1

```
root@kali:~# aireplay-ng -9 -e EurekaLabs -a B0:C7:45:75:BD:C6 wlan1mon
17:32:57  Waiting for beacon frame (BSSID: B0:C7:45:75:BD:C6) on channel 11
17:32:57  Trying broadcast probe requests...
17:32:57  Injection is working!
17:32:58  Found 1 AP

17:32:58  Trying directed probe requests...
17:32:58  B0:C7:45:75:BD:C6 - channel: 11 - 'EurekaLabs'
17:32:59  Ping (min/avg/max): 2.105ms/26.305ms/59.914ms Power: -21.00
17:32:59  30/30: 100%
```

Figure 1: Successful Injection Test

The last line is important—it should be a very high-percentage. If it is not, there may be a driver issue. However, as long as it is not 0%, you should still be able to complete the lab.

```
root@kali:~# aireplay-ng -1 0 -e EurekaLabs -a B0:C7:45:75:BD:C6 -h 7C:DD:90:98:95:D0 wlan1mon
17:07:14  Waiting for beacon frame (BSSID: B0:C7:45:75:BD:C6) on channel 11

17:07:14  Sending Authentication Request (Open System) [ACK]
17:07:14  Authentication successful
17:07:14  Sending Association Request [ACK]
17:07:14  Association successful :-) (AID: 1)
```

Figure 2: Example of Successful Association with AP

3 Capturing Data

We will again use `airodump-ng` to capture data. Open a separate terminal tab or window and use the following command:

```
# airodump-ng -c channel --bssid network-bssid -w outputfile wlan0mon
```

You should see the familiar `airodump-ng` output in the terminal, even though no data may be collected yet. We will provide data in the injection portion of the lab.

4 Counterfeit Authentication and Association

In order to communicate with the AP, a client must be authenticated and associated. This is a problem for us, since we do not know the appropriate WEP key to authenticate with the AP. However, if we *spoof* our MAC address to appear like we are an already authenticated client, we can still inject traffic in to the network. The router will reject them as bad packets, **but this still allows us to collect IV's from the network**. The ability to collect new IV's on bad packets is the most major security vulnerability of the WEP protocol.

In another terminal tab, use the following `airreplay-ng` command to falsely associate with the AP

```
# aireplay-ng -1 0 -e network-ssid -a network-bssid -h client-mac wlan0mon
```

The client MAC address should have been discovered in Section 1. We will use this MAC address to masquerade as a legitimate client. Fig. 2 shows what a successful association output.

5 Traffic Generation via ARP Replay

In order to crack the WEP key, an attacker needs to generate a huge amount of traffic. The purpose of this step is to start `aireplay-ng` in a mode which listens for ARP requests then injects them back into the network (ARP *replay*). The reason that we select ARP requests is because the AP will normally broadcast them **with a new IV each time**. Again our objective is to obtain a large number of IV's in a short period of time.

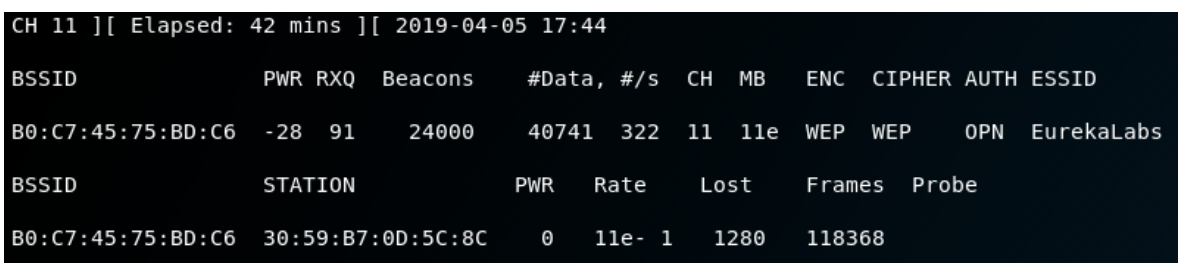
After you've successfully associated, use the following command to begin the ARP replay attack

```
# aireplay-ng -3 -b network-bssid -h client-mac wlan0mon
```

It is important to see the number of ARP requests increase very fast. However, it is possible that you cannot capture even one ARP request packet, which happens when the network is idle. If you did not get the ARP injection going after a few minutes, you should ask your instructor to create some traffic.

It is also possible that you may NOT be able to inject if someone else is doing an ARP replay attack at the same time. Since a huge amount of packets are sent to the AP by the attacker, the AP is too busy to respond to your injection. In this case, you could replace your NIC MAC address (the -h parameter) with a MAC address that is already associated with the AP (such as the MAC address of an associated client) being used in the existing ARP replay attack. You already obtained an associated client's MAC address in the first section, but you can also use `airodump-ng` to check the activity levels associated with other MAC addresses. Reassociate using a highly active MAC address.

You can confirm that you are injecting by checking your airodump-ng screen. The data packets should be increasing rapidly. The "#/s" should be a decent number. A typical range is 300 to 400 data packets per second. It can be as low as a 100/second or as high as a 500/second. Fig. 3 shows an example.



```
CH 11 ][ Elapsed: 42 mins ][ 2019-04-05 17:44

BSSID              PWR RXQ  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

B0:C7:45:75:BD:C6  -28  91    24000    40741  322  11  11e  WEP  WEP    OPN  EurekaLabs

BSSID              STATION            PWR   Rate    Lost    Frames  Probe

B0:C7:45:75:BD:C6  30:59:B7:0D:5C:8C    0   11e- 1   1280   118368
```

Figure 3: ARP Packet Collection

If you receive a message similar to "Got a deauth/disassoc packet. Is the source MAC associated?" you have lost association with the AP, and all your injected packets will be ignored, even if `airodump-ng` is still collecting data. You must return to the fake authentication step and successfully associate with the AP. It is helpful to have separate terminal tabs or windows open for the `airodump-ng`, `aireplay-ng` association, and `aireplay-ng` attack commands.

If you still are not able to collect ARP packets, it may be necessary to force clients to reconnect. Stop the `aireplay-ng` attack command (leave `airodump-ng` running though) and deauthenticate

the active client using the following instruction:

```
# aireplay-ng -1 0 -e network-ssid -a network-bssid -h client-mac wlan0mon
```

This command will continuously issue a "death packet" to the client whose MAC address matches the -h parameter. Let this command run for a minute or two. Eventually, you should see very few ACK's being returned of the ones issued. Stop this command, reassociate with the AP, and restart the `aireplay-ng` attack. Once a computer connects, it blasts out ARP packets to determine its network "neighbors," so to speak. This is an easy way to generate plenty of ARP packets, especially if the target computer is set to automatically connect to the test network.

5.0.1 Provide a screenshot of the ARP injection and replay.

5.0.2 If the instructor did not create traffic for you, what will you do to create traffic? Remember, you have not yet joined the network.

6 Key Cracking

This section is identical to the Basic version of this lab. There are two algorithms provided in `aircrack-ng` that enable us to decrypt the WEP key. The first is the PTW attack, one of the fastest WEP key cracking algorithms. This crack is performed with the following command:

```
# aircrack-ng -z -b network-bssid capturefile.cap
```

The second method is called KoreK, FMS, or chopchop attack. This crack is performed with the following command:

```
# aircrack-ng -K -b network-bssid capturefile.cap
```

In both above examples, `capturefile.cap` should be the file written to by `airodump-ng`.

6.0.1 Explain both above attack techniques (PTW and KoreK). The `aircrack-ng` reference may be useful: `http://www.aircrack-ng.org/doku.php?id=aircrack-ng`.

6.0.2 What is the WEP key (in ASCII format)? Provide a screenshot of the successful crack.

6.0.3 Explain the meaning of the terms "Depth Field" and "Fudge Factor."

Depending on the collected packets, one, or both, of the algorithms may fail. Try to run `aircrack-ng` with different Depth Field and Fudge Factor parameters (especially the FMS/KoreK attack).

6.0.4 Which method recovers the WEP key faster/more reliably? Why?

7 Network Reconnaissance

Accessing a network is the first step, but an adversary needs to find information about the clients/servers hosted on that network. Join the network using the recovered key.

7.0.1 In Linux, you can join a network using only the `iwconfig` command in Terminal. List the detailed commands to join a network.

Hints: Use `iwconfig` to supply the necessary information to join the network. The key parameters used in `iwconfig` are: *essid, channel, enc*. If you are associated with the desired AP, you can set a static IP using `ifconfig` or get an DHCP IP using `dhclient`.

Since you already have the MAC address of a connected client, all you need to do is discover its IP address. Reverse Address Resolution Protocl (RARP) is no longer supported by many machine kernels. Instead, use the NMAP tool to scan for available IP addresses. The command is

```
# nmap -sP 192.168.1.0/24
```

7.0.2 Provide the IP address of a connected client.

The next step is to perform OS fingerprinting. If the attacker does not have a specific target in mind, they will want to pick an OS vulnerable to direct attacks. To determine information about a client, use

```
# nmap -O -v target-ip-address
```

For more information about OS fingerprinting, see the NMAP reference: `http://nmap.org/book/osdetect.html`.

7.0.3 Provide a screenshot of your OS fingerprinting results.

8 Discussion Questions

8.0.1 What is the most significant advantage of this WEP key crack approach?

8.0.2 What is the basic requirement for this WEP key crack approach?

8.0.3 What is the biggest problem with this key crack approach?

8.0.4 How would you prevent this type of attack on a WEP network?

8.0.5 Once the WEP key is discovered by adversaries, what can you do to protect a Wi-Fi network?

8.0.6 Assume that a MAC filter is enabled on the AP of this wireless network. Additionally, there is no traffic in the network. What will you do differently to crack the WEP key?

9 General Questions

9.0.1 How long did it take you to complete this lab?

9.0.2 Was this lab challenging enough?